

Bab 2

Prinsip Dasar Keamanan Informasi (CIA Triad)

Pokok Bahasan

Pendalaman konsep *Confidentiality, Integrity, Availability (CIA Triad)* sebagai fondasi pengendalian keamanan informasi; pemetaan ancaman–kontrol; metrik keberhasilan; serta studi kasus penerapan CIA pada konteks organisasi modern.

Topik Bahasan

1. *Confidentiality* (Kerahasiaan): klasifikasi informasi, IAM/MFA, prinsip *least privilege*, enkripsi (at rest/in transit), DLP.
2. *Integrity* (Integritas): hashing & digital signature, checksum, kontrol versi, logging & audit trail, kontrol basis data (constraint/trigger).
3. *Availability* (Ketersediaan): redundansi (HA/cluster), backup & recovery (aturan 3-2-1, RPO/RTO), kapasitas & *rate limiting*, proteksi DoS/WAF.
4. Studi Kasus: identifikasi aspek CIA yang terdampak, akar masalah, dan rancangan mitigasi.
5. Metrik & *Trade-off*: uptime %, MTTR/MTBF, rasio insiden tanpa izin, akurasi integritas (hash match), keseimbangan CIA di desain sistem.

Capaian Pembelajaran

Setelah menyelesaikan Bab 2, mahasiswa mampu untuk:

1. Mendefinisikan dan menjelaskan *CIA Triad* secara akurat dan kontekstual.

2. Menganalisis insiden/pelanggaran untuk menentukan aspek CIA yang terdampak beserta akar penyebabnya.
3. Memetakan ancaman → kontrol yang relevan pada tiap aspek CIA serta merumuskan rekomendasi mitigasi.
4. Menyusun rencana uji (confidentiality, integrity, availability) beserta metrik dasar keberhasilannya.

Indikator Ketercapaian

1. Menyajikan definisi CIA yang tepat beserta ≥ 2 contoh ancaman per aspek.
2. Pada satu studi kasus, menentukan aspek CIA yang dilanggar dengan justifikasi (alur sebab-akibat).
3. Mengusulkan ≥ 3 kontrol yang spesifik & dapat diterapkan untuk tiap aspek yang terdampak.
4. Menuliskan rencana uji singkat:
 - a) *Confidentiality*: uji matriks akses, uji enkripsi (TLS/At-rest).
 - b) *Integrity*: verifikasi *hash/signature* dan konsistensi data.
 - c) *Availability*: simulasi failover, validasi RTO/RPO.
5. Menentukan ≥ 2 metrik (mis. uptime %, jumlah akses tidak sah, tingkat kegagalan verifikasi hash, MTTR) dan targetnya.

2.1 Confidentiality, Integrity, Availability (CIA)

CIA Triad merupakan model inti keamanan informasi yang memastikan aset informasi tetap rahasia, utuh, dan tersedia. *Confidentiality (C)* mencegah pengungkapan tidak sah dengan klasifikasi data, *IAM + MFA*, prinsip *least privilege*, enkripsi (*at rest/in transit*), serta *DLP/masking*. *Integrity (I)* menjaga informasi tetap lengkap dan akurat melalui *hashing* dan tanda tangan digital, checksum, kontrol versi, transaksi/constraint basis data, dan pencatatan yang tahan gangguan (mis. log imut/WORM). *Availability (A)* memastikan akses yang andal dan tepat waktu melalui redundansi/HA, *capacity planning* dan *autoscaling*, *backup 3-2-1* dengan uji pemulihan, mitigasi DoS/WAF, serta pemantauan dan *incident response*. Keseimbangan CIA penting: enkripsi berat (C) tanpa perencanaan kapasitas dapat menurunkan ketersediaan (A); logging berlebihan untuk audit (I) dapat mengganggu performa (A). Karena itu, desain harus berbasis risiko dengan metrik yang jelas (mis. tingkat akses tak sah, % aset terenkripsi, tingkat ketidakcocokan hash, *uptime*/MTBF, MTTD/MTTR, RTO/RPO) agar kontrol dapat dievaluasi dan ditingkatkan berkelanjutan.

2.2 Studi Kasus Penerapan CIA Triad

Berikut adalah beberapa studi kasus dalam penerapan CIA :

Studi Kasus 1 — Phishing kredensial CRM (Confidentiality)		
1	Ringkasan	Akun staf pemasaran dikompromi lewat phishing; data pelanggan diunduh.
2	Aspek CIA terdampak	C (utama), potensi I (perubahan data)

3	Akar masalah	MFA tidak aktif, awareness rendah, DMARC/SPF/DKIM belum ketat.
4	Kontrol & mitigasi	Wajib MFA, pelatihan phishing berkala + simulasi, kebijakan kata sandi, DLP/CASB untuk ekspor data, hardening email (SPF, DKIM, DMARC).
5	Metrik uji	Click rate simulasi phishing < 5%; cakupan MFA 100%; blokir ekspor data tak berizin = 0

Studi Kasus 2 — Ransomware di RS (Availability + Integrity)		
1	Ringkasan	Server rekam medis terenkripsi; layanan klinik terganggu 10 jam.
2	Aspek CIA terdampak	A (utama), I (potensi korupsi data), C (kebocoran).
3	Akar masalah	Patch lambat, PC tanpa EDR, segmentasi jaringan lemah, backup tidak teruji..
4	Kontrol & mitigasi	Patch manajemen rutin, EDR/antiransomware, segmentasi + SMB hardening, prinsip least privilege, backup 3-2-1 + uji pemulihan, aplikasi <i>allow-list</i> .
5	Metrik uji	RTO ≤ 4 jam, RPO ≤ 1 jam; coverage patch kritikal > 95%; tingkat deteksi EDR > 99%.

Studi Kasus 3 — SQL Injection pada Web Pembayaran (Integrity + Confidentiality)		
1	Ringkasan	Penyerang menyisipkan SQL untuk membaca & memodifikasi transaksi.

2	Aspek CIA terdampak	I (utama), C (data bocor).
3	Akar masalah	Query konkatenatif, input validation lemah, hak DB terlalu luas
4	Kontrol & mitigasi	Prepared statements/ORM, validasi & sanitasi input, WAF, least privilege di DB (read/write terpisah), logging + alert anomali kueri.
5	Metrik uji	Coverage uji keamanan input 100%; upaya SQLi diblokir WAF > 99%; audit hak DB lulus 100%.

Studi Kasus 4 — Bucket Cloud Terbuka (Confidentiality)		
1	Ringkasan	Arsip laporan keuangan pada penyimpanan cloud publik dapat diakses umum.
2	Aspek CIA terdampak	C (utama)
3	Akar masalah	Kebijakan bucket “public read”, tidak ada guardrail konfigurasi.
4	Kontrol & mitigasi	IAM least privilege, enkripsi at-rest, blokir akses publik by policy, Config/Policy rules otomatis, akses via VPC endpoint, monitoring & alert misconfig.
5	Metrik uji	Kepatuhan rule “no public bucket” = 100%; temuan misconfig = 0; enkripsi at-rest 100%.

Studi Kasus 5 — Insider Menghapus Log Insiden (Integrity)		
1	Ringkasan	Admin menghapus log untuk menutupi akses ilegal di malam hari.
2	Aspek CIA terdampak	I (utama), A (ketika investigasi terganggu).
3	Akar masalah	Tidak ada pemisahan tugas, log tidak imut, SIEM tanpa integritas hash.
4	Kontrol & mitigasi	<i>Segregation of duties, WORM/immutable logging, forward</i> ke SIEM dengan hashing/timestamp, approval berlapis untuk akses admin, <i>continuous monitoring</i> + UEBA.
5	Metrik uji	Persentase log pada storage immutable 100%; pelanggaran SoD 0; alarm SIEM untuk penghapusan log terpicu < 1 menit.

Ancaman tambahan yang tidak dirinci pada studi kasus disajikan pada Tabel 2.1 sebagai referensi ringkas

Tabel 2.1 Ringkasan Ancaman → CIA → Kontrol → Metrik

No	Ancaman	Aspek CIA Terdampak	Kontrol Utama (contoh)	Metrik Keberhasilan (indikator)
1	Phishing kredensial	C (utama), I (turunan)	MFA, kebijakan sandi, pelatihan & simulasi phishing, SPF/DKIM/DMARC, DLP/CASB	Cakupan MFA 100%; click rate simulasi <5%; ekspor data tak berizin =0

2	Ransomware	A (utama), I/C	Patch manajemen, EDR/anti-ransomware, segmentasi jaringan, least privilege, backup 3-2-1 + uji pemulihan	RTO ≤ 4 jam; RPO ≤ 1 jam; kepatuhan patch kritikal >95%; deteksi EDR >99%
3	SQL Injection (Web)	I (utama), C	Prepared statements/ORM, validasi & sanitasi input, WAF, hak DB minimal, logging & alert anomali	Upaya SQLi diblokir >99%; kueri sensitif 100% pakai prepared; temuan uji injeksi =0
4	Misconfig bucket cloud publik	C	IAM least-privilege, blok akses publik by policy, enkripsi at-rest, config/guardrail otomatis	Bucket publik =0; enkripsi at-rest 100%; kepatuhan policy 100%
5	Insider menghapus log	I (utama), A	Segregation of duties (SoD), WORM/immutable logging, SIEM + hashing & timestamp, PAM	Log pada storage immutable 100%; pelanggaran SoD =0; waktu deteksi penghapusan <1 menit
6	DDoS	A	CDN/WAF, auto-scaling, rate limiting, upstream scrubbing	Waktu mitigasi otomatis <2 menit; uptime ≥99,9% saat serangan

7	MITM di jaringan publik	C, I	TLS-everywhere + HSTS, VPN/Zero Trust, certificate pinning, edukasi pengguna	Cakupan TLS 100%; HSTS preload aktif; insiden MITM terkonfirmasi =0
8	Perangkat hilang/tercuri	C, A	Full-disk encryption, MDM (remote wipe), kebijakan screen-lock, backup terjadwal	Enkripsi perangkat 100%; kepatuhan MDM >95%; median waktu remote-wipe <15 menit; keberhasilan backup >99%

Catatan: Angka pada metrik adalah baseline contoh; silakan sesuaikan dengan kebijakan institusi/RPS (target SLA, regulasi, dan profil risiko).

2.3 Latihan Terbimbing: Rencana Mitigasi & Metrik

Pilih salah satu kasus dari contoh studi kasus diatas lalu lakukan langkah-langkah berikut :

- 1) Nyatakan masalah & CIA terdampak: jelaskan ringkas (3–4 kalimat) dan tandai C/I/A utama.
- 2) Akar masalah: lakukan 5 *Whys* singkat atau diagram sebab–akibat (bullet point).
- 3) Tujuan (SMART): tetapkan 2–3 tujuan mitigasi yang spesifik & terukur (mis. “RTO $\leq$ 4 jam dalam Q3”).
- 4) Kontrol prioritas: pilih 3–5 kontrol utama (Prevent–Detect–Respond–Recover) dan petakan ke ISO 27001/NIST/OWASP.

- 5) Rencana implementasi: siapa (owner), apa (task), kapan (deadline), sumber daya (tool/anggaran).
- 6) Metrik & ambang target: tentukan leading (proses) & lagging (hasil), cara ukur, frekuensi, dan target numerik.
- 7) Uji & verifikasi: bagaimana menguji efektivitas (simulasi/DR test/pen-test) + kriteria lulus.
- 8) Risiko residual & tindak lanjut: apa yang masih tersisa dan rencana peningkatan berikutnya.

Gunakan template berikut untuk melakukan latihan ini :

A. Kasus & CIA

- a) Kasus:
- b) CIA terdampak (beri tebal salah satu): C / I / A
(+ turunan: ____)

B. Akar Masalah (5 Whys ringkas)

- a) Kenapa 1: ... → Kenapa 2: ... → Kenapa 3: ... → Kenapa 4: ... → Kenapa 5: ...
- b)

C. Tujuan SMART (2–3 butir)

- a) ... (*mis. "Click rate phishing <5% pada Q2"*)
- b) ...
- c) ...

D. Kontrol Prioritas (3–5 butir, +acuan standar)

- a) Kontrol: ... |Jenis: Prevent/Detect/Respond/Recover|
Acuan: ISO 27001 A.xx / NIST CSF / OWASP ...
- b)

E. Rencana Implementasi (mini-RACI)

Task	Owner	Due date	Resource/Tool	Catatan
...	...	...	...	...

F. Metrik & Target

Metrik	Jenis	Rumus/Sumber Data	Frekuensi	Target
RTO	Lagging	Durasi pemulihan (DR test)	Triwulan	≤ 4 jam
...	...	...	...	...

G. Uji & Verifikasi

- a) Metode uji: (simulasi DR/pen-test/tabletop) ...
- b) Kriteria lulus: ...

H. Risiko Residual & Next Step

- a) Residual: ... | Rencana peningkatan: ...
- b)

Instruksi Pengumpulan

- a) Individu, 1–2 halaman (maks 800 kata), format tabel di atas.
- b) Cantumkan rujukan standar yang dipakai (ISO 27001/NIST/OWASP).

Contoh 2.1 (Ransomware di RS) – Template Terisi

Contoh ini hanya menunjukkan format dan kedalaman analisis (alur: masalah → akar sebab → tujuan SMART → kontrol → metrik), bukan kunci jawaban untuk semua skenario. Saat mengerjakan

Latihan 2.3, pilih satu ancaman dari Tabel 2.1 *atau* kasus nyata lain, lalu adaptasikan:

- a) CIA utama/turunan sesuai konteks Anda.
- b) Kontrol (Prevent/Detect/Respond/Recover) yang benar-benar relevan (boleh berbeda dari contoh).
- c) Metrik (*leading/lagging*) yang dapat diukur di lingkungan Anda.

Penilaian menitikberatkan pada argumentasi berbasis risiko, pemetaan ke standar (ISO/IEC 27001, NIST CSF, OWASP), serta kejelasan rencana implementasi—bukan kemiripan dengan contoh. Tunjukkan variasi, kreativitas, dan justifikasi yang kuat untuk konteks yang Anda pilih.

A. Kasus & CIA

- a) Kasus: Server rekam medis (EMR= Electronic Medical Record) terenkripsi oleh ransomware; layanan klinik berhenti 10 jam.
- b) CIA terdampak (beri tebal salah satu): C / I / A (A utama; turunan: I, C)

B. Akar Masalah (5 Whys ringkas)

- a) Kenapa 1: Patch Windows & aplikasi tertunda → Kenapa 2: Tidak ada siklus patch mingguan → Kenapa 3: Minim inventaris & prioritisasi CVE → Kenapa 4: Kurang tool otomatis (WSUS/Intune) → Kenapa 5: Tidak ada KPI patch & akuntabilitas.
- b) Tambahan: EDR belum terpasang merata; jaringan flat (SMB terbuka); backup belum diuji pemulihannya.

C. Tujuan SMART (2–3 butir)

- a) RTO $\leq$ 4 jam untuk EMR pada akhir Q3.
- b) RPO $\leq$ 1 jam untuk database EMR pada akhir Q3.
- c) Kepatuhan patch kritikal >95% dalam 60 hari dan terjaga bulanan.

D. Kontrol Prioritas (3–5 butir, +acuan standar)

- a) Patch management terjadwal | Jenis: Prevent | Acuan: ISO 27001 A.8.8, NIST CSF PR.IP-12
- b) EDR/anti-ransomware di endpoint & server | Detect/Respond | ISO A.8.16, NIST CSF DE.CM
- c) Segmentasi jaringan & hardening SMB | Prevent | ISO A.8.20, NIST CSF PR.AC
- d) Backup 3-2-1 + uji pemulihan triwulanan | Recover | ISO A.8.13, NIST CSF RC.IM
- e) IR playbook & tabletop exercise | Respond | ISO A.5.24, NIST CSF RS.RP

E. Rencana Implementasi (mini-RACI)

Task	Owner	Due date	Resource/Tool	Catatan
Inventaris aset & prioritas CVE	SecOps Lead	T+14 hari	Scanner vuln (Nessus)	Basis patch window
Otomasi patch & kebijakan	IT Ops Lead	T+30 hari	WSUS/Intune	KPI bulanan
Deploy EDR ke 100% aset	SecOps Lead	T+45 hari	EDR (Defender/Carbon Black)	Termasuk server EMR

Segmentasi VLAN & blok SMB	Network Eng	T+40 hari	Firewall, ACL	Least privilege
Backup 3-2-1 & DR drill	DBA/BCP Lead	T+60 hari	Veeam/Repo offline	Uji restore penuh
IR tabletop ransomware	CISO	T+50 hari	Playbook IR	Simulasi lintas tim

F. Metrik & Target

Metrik	Jenis	Rumus/Sumber Data	Frekuensi	Target
RTO EMR	Lagging	Durasi pemulihan saat DR test	Triwulan	≤ 4 jam
RPO EMR	Lagging	Selisih waktu backup-insiden	Triwulan	≤ 1 jam
Patch kritisal	Leading	% host patched (≤30 hari)	Bulanan	≥ 95%
Cakupan EDR	Leading	% aset terlindungi	Mingguan	100%
Keberhasilan restore	Lagging	% restore sukses pada drill	Triwulan	≥ 99%
Waktu deteksi EDR	Leading	MTTD dari alert ke triase	Bulanan	≤ 5 menit

G. Uji & Verifikasi

- Metode uji: DR drill terjadwal (full restore), tabletop IR ransomware, pen-test internal untuk lateral movement.

- b) Kriteria lulus: Restore penuh ≤ 4 jam; kehilangan data ≤ 1 jam; patch $\geq 95\%$; EDR coverage 100%; MTTR ≤ 5 menit.

H. Risiko Residual & Next Step

- a) Residual: Risiko zero-day & human error tetap ada.
Rencana peningkatan: tambah isolasi aplikasi (allow-listing), phishing drill berkala, offsite immutable backup (WORM).
- b) Evaluasi tahunan arsitektur Zero Trust; integrasi SOAR untuk respons lebih cepat.

2.4 Refleksi Diri:

Bagian ini mengajak Anda merefleksikan kebiasaan keamanan pribadi melalui lensa CIA: C—aktifkan MFA, gunakan password manager, enkripsi perangkat; I—hindari phishing, gunakan versi/checksum untuk menjaga keutuhan file; A—siapkan backup 3-2-1 dan uji pemulihan. Tuliskan ± 150 kata tentang kondisi saat ini, lalu tetapkan dua aksi SMART untuk 7 hari (mis. aktifkan MFA akun utama, atur backup & uji restore ≤ 15 menit). Pantau kemajuan via % akun ber-MFA, jumlah sandi unik, frekuensi backup.

2.5 Rubrik Penilaian

Total point : 100

- a) Pemilihan & pemahaman kasus (10)
- b) Akar masalah & CIA terdampak (15)
- c) Tujuan SMART yang relevan (15)
- d) Kontrol prioritas + pemetaan ke standar (20)
- e) Rencana implementasi (mini-RACI) (15)

- f) Metrik terukur (leading & lagging) (15)
- g) Uji & verifikasi + kriteria lulus (5)
- h) Refleksi ringkas & realistis (5)

Referensi

Whitman & Mattord (2021); Stallings & Brown (2020);
ISO/IEC 27001 (ISMS);
NIST Cybersecurity Framework;
OWASP Top 10 (2023).

Latihan pendahuluan:

1. Buat list 30 ancaman potensial: jenis ancaman, Apek CIA terdampak, Metode serangan, Kontrol dan mitigasi (gambarkan)
2. Buat list istilah pada bab 2
3. Buat kesimpulan

